

HackTheBox CTF: Brutus Lab

Penetration Testing & Exploitation Report

1. Executive Summary

This report details the penetration testing steps executed to compromise the **Brutus Lab** on the HackTheBox (HTB) platform. The primary objective of this exercise was to identify and exploit weak authentication mechanisms on the Secure Shell (SSH) service using dictionary-based brute-force techniques.

2. Tools Utilized

Nmap

Hydra

SSH Client

SecLists (rockyou.txt)

3. Attack Methodology & Execution

Step 1: Network Reconnaissance (Nmap)

Action: Conducted a comprehensive port scan against the target IP to identify active services and potential entry points.

Command Executed:

```
nmap -sC -sV -p- 10.10.11.x
```

Finding: Port 22 (SSH) was discovered open, running OpenSSH. With no other vulnerable web services exposed, SSH was identified as the primary attack vector.

Step 2: Brute-Force Exploitation (Hydra)

Action: Launched a dictionary-based brute-force attack against the SSH service. The attack targeted default administrative usernames (e.g., 'root', 'admin') utilizing the rockyou.txt wordlist.

Command Executed:

```
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://10.10.11.x -t 4
```

Finding: The Hydra tool successfully cracked the password. The valid credentials identified were **root : qwerty123**.

Step 3: Initial Access & Flag Retrieval

Action: Authenticated to the target machine via the terminal using the compromised credentials.

Command Executed:

```
ssh root@10.10.11.x
```

Finding: Successfully gained shell access as the root user. Navigated to the home directory and retrieved the flag located in `/root/root.txt`, completing the lab objective.

4. Vulnerability Remediation & Recommendations

To prevent similar brute-force attacks in a production environment, the following security controls must be implemented immediately:

- **Enforce Key-Based Authentication:** Disable password authentication entirely (`PasswordAuthentication no`) and mandate public-key (RSA/Ed25519) authentication for all SSH logins.
- **Implement Rate Limiting:** Deploy tools like **Fail2Ban** to automatically block IP addresses after a specified number of failed login attempts.
- **Disable Direct Root Login:** Set `PermitRootLogin no` in the `sshd_config` file to force users to log in with standard accounts before escalating privileges.